

Overall Risk: Medium

3.75 / 10

Modules Run	Critical	High	Medium
4	4	0	3

The system presents a MEDIUM security risk (score 3.75/10). Several security improvements are recommended.

This report was generated by the Windows Security Audit Tool. Findings should be reviewed before implementing remediation. Frameworks referenced: NIST SP 800-63B, CIS Controls v8, Microsoft Security Baseline, OWASP Testing Guide v4.

Executive Summary

The system presents a MEDIUM security risk (score 3.75/10). Several security improvements are recommended.

Module Risk Breakdown

Assessment Area	Weight	Score	Risk Level	Data
Firewall Configuration	30%	2/10	Low	Yes
Password Policy	25%	7/10	High	Yes
Port Exposure	25%	4/10	Medium	Yes
System Information	20%	2/10	Low	Yes

Overall Risk Score: 3.75/10 — Medium

Firewall Configuration

Low — 2/10

About this assessment area:

The Windows Firewall acts as a barrier between your computer and the network, controlling which connections are permitted. A disabled or misconfigured firewall exposes services running on your system to direct network attack. The Verizon Data Breach Investigations Report (2023) consistently identifies network-level attacks as a leading breach vector, making firewall configuration a priority control under CIS Controls v8 (Control 4).

Findings

MEDIUM

MEDIUM: Defender definitions outdated (343 days old)

Recommendations

1. Update Windows Defender virus definitions

Password Policy

High — 7/10

About this assessment area:

Password policies define the rules users must follow when creating and maintaining passwords. Weak policies enable credential-based attacks including brute force (automated password guessing) and credential stuffing (replaying leaked passwords from other breaches). NIST SP 800-63B recommends a minimum of 8 characters, while CIS Benchmarks recommend 14+ characters. Account lockout policies limit failed login attempts, preventing automated guessing attacks (CIS Control 5).

Findings

CRITICAL	CRITICAL: Minimum password length is only 0 characters
MEDIUM	MEDIUM: Password history only remembers 0 passwords
LOW	LOW: No minimum password age (allows password cycling)
INFO	INFO: Password policy compliance level is Poor (31.2%)

Recommendations

1. Immediately increase minimum password length to at least 8 characters
2. Increase password history to at least 24 passwords
3. Set minimum password age to 1 day

Network Port Exposure

Medium — 4/10

About this assessment area:

Every open network port is a potential entry point for attackers. Services listening on ports may contain exploitable vulnerabilities. The principle of least exposure dictates only necessary services should be accessible. Standard Windows services such as RPC (135), NetBIOS (139), and SMB (445) are required for normal operation but must be protected by an active firewall. NIST SP 800-115 recommends local port enumeration as part of any host security assessment (CIS Control 12).

Findings

CRITICAL	CRITICAL: MS-RPC (port 135) is listening - Windows RPC, frequently exploited
CRITICAL	CRITICAL: NetBIOS (port 139) is listening - Legacy file sharing, information disclosure
CRITICAL	CRITICAL: SMB (port 445) is listening - File sharing, ransomware vector (WannaCry, EternalBlue)
INFO	INFO: 3 standard Windows service port(s) (135/139/445) score-adjusted because firewall is active

Recommendations

1. Immediately disable MS-RPC on port 135 or restrict to localhost only
2. Immediately disable NetBIOS on port 139 or restrict to localhost only
3. Immediately disable SMB on port 445 or restrict to localhost only

System Information

Low — 2/10

About this assessment area:

The system patch status directly determines exposure to known vulnerabilities. Unpatched systems remain vulnerable to exploits for which fixes are publicly available. End-of-life operating systems no longer receive security updates, leaving all subsequently discovered vulnerabilities permanently unpatched. CIS Controls v8 identifies patch management as a foundational security control.

Findings

MEDIUM	MEDIUM: Guest account exists on this system. Guest accounts allow unauthenticated access.
INFO	INFO: Operating system (Windows 11) is currently supported

Recommendations

1. Disable the Guest account via: Computer Management → Local Users and Groups → Users

Prioritised Remediation Plan

Recommendations are ordered by the risk score of their source module. Addressing these items in order achieves the greatest risk reduction.

#	Area	Recommended Action
1	Password	Immediately increase minimum password length to at least 8 characters
2	Password	Increase password history to at least 24 passwords
3	Password	Set minimum password age to 1 day
4	Port	Immediately disable MS-RPC on port 135 or restrict to localhost only
5	Port	Immediately disable NetBIOS on port 139 or restrict to localhost only
6	Port	Immediately disable SMB on port 445 or restrict to localhost only
7	Firewall	Update Windows Defender virus definitions
8	System	Disable the Guest account via: Computer Management → Local Users and Groups → Users

Appendix: Assessment Frameworks

This assessment references the following authoritative security frameworks. Findings are mapped to multiple standards to provide comparative compliance analysis rather than imposing a single configuration standard, as described in the research objectives.

Framework	Area	Relevant Guidance
NIST SP 800-63B	Password Policy	Minimum 8 character passwords; check against breached password lists
NIST SP 800-115	Port Assessment	Local port enumeration for host security assessment
NIST SP 800-30 Rev 1	Risk Scoring	Weighted risk assessment considering likelihood and impact
CIS Controls v8 — Ctrl 4	Firewall	Secure configuration; firewall enabled on all profiles
CIS Controls v8 — Ctrl 5	Password Policy	14+ character minimum; lockout after 5 attempts
CIS Controls v8 — Ctrl 12	Port Assessment	Disable unnecessary services; network infrastructure management
Microsoft Security Baseline	Password Policy	Enable complexity; 14 character minimum; lockout threshold of 10
OWASP Testing Guide v4	Port Assessment	Network port and service identification as part of security testing

References: Verizon (2023) Data Breach Investigations Report; NIST SP 800-30 Rev 1; NIST SP 800-63B; NIST SP 800-115; CIS Controls v8 (2021); Microsoft Security Baseline Windows 11; OWASP Testing Guide v4.